

PsyClick Secure

Risk Assessment Report

CS0029 — Information Assurance and Security — Standalone Deep-Dive Deliverable

Field	Value
System	PsyClick Secure (psyclick-secure build)
Prepared for	CS0029 Final Project — Risk Assessment Report deliverable (Section IX)
Assessment date	11 July 2026
Scope	psyclick-secure backend (api_server.py, database_manager.py, security_manager.py, backend_controller.py, intrusion_monitor.py, supabase_sync.py) and frontend (React/Electron) source tree
Method	Source-code review, threat modeling (STRIDE), static analysis (bandit), dependency audit (npm audit), and qualitative likelihood/impact scoring; no live network penetration test was performed — see Security Testing Report
Prepared by	PsyClick thesis team, with source-level tooling evidence captured in this workspace

1. Purpose and Scope

This report provides the in-depth risk assessment referenced in Chapter 5, Section 5.4.4 of the PsyClick thesis and required as a standalone deliverable under CS0029 Section IX (“Risk Assessment Report”). It expands the summary risk matrix embedded in the thesis into a full risk register with explicit scoring methodology, asset inventory, threat-actor profiles, inherent vs. residual risk, and a treatment roadmap.

Scope is limited to the psyclick-secure application (a separate, hardened build of the PsyClick clinical decision support prototype) and its immediate deployment environment: a single clinician workstation running the Electron/React frontend against a local Flask API bound to 127.0.0.1, backed by a local SQLite database with optional Supabase cloud sync. Institution-wide network infrastructure, physical security of the facility, and third-party cloud provider risk (Supabase) are noted where relevant but are outside the direct code-level control boundary of this project.

2. Methodology

2.1 Risk Scoring Model

Each risk is scored on two 1–5 scales and combined multiplicatively ($\text{Likelihood} \times \text{Impact} = \text{Risk Score}$, range 1–25), consistent with common qualitative risk-matrix practice used in ISO/IEC 27005-aligned assessments.

Score	Likelihood	Impact (Confidentiality / Integrity / Availability of clinical data)
1	Rare — would require an unlikely combination of failures	Negligible — no clinical data or trust impact
2	Unlikely — possible but not expected under normal operation	Minor — limited, recoverable impact
3	Possible — could occur, especially without the stated control	Moderate — a single client/session record affected
4	Likely — expected to occur periodically without mitigation	Major — multiple records or a full account compromised
5	Almost certain — trivial to trigger without the stated control	Severe — breach of restricted clinical/behavioral data, RA 10173 exposure, or loss of system trust

Risk Score	Band
1–4	Low
5–11	Medium
12–19	High
20–25	Critical

2.2 Inherent vs. Residual Risk

“Inherent risk” is scored as if the described control did not exist. “Residual risk” is scored after accounting for the control(s) actually present in the reviewed psyclick-secure source code as of 11 July 2026, verified either by direct code reading or by the automated test/scan evidence in the companion Security Testing Report. Where a control is only partially implemented, the residual score reflects that partial state rather than the ideal end state.

3. Asset Inventory and Classification

Asset	Classification	Why it matters
Clinician credentials (password hash, session tokens)	Restricted	Compromise enables impersonation and full account takeover
Patient/client pseudonymous identifiers and session metadata	Restricted (RA 10173 personal/behavioral data)	Re-identification risk; behavioral biometric data requires elevated protection
Raw keystroke/cursor telemetry and derived features (T ² , PSI, PAI)	Restricted	Classified as behavioral biometric data; sensitive even when de-identified
PHQ-9 / GAD-7 screening scores	Restricted (clinical/health data)	Direct mental-health indicator; highest sensitivity
Clinical session reports (HTML/export)	Restricted	Aggregates multiple restricted data types into one exportable artifact
Audit log	Confidential / Integrity-critical	Sole accountability record; must be tamper-evident
Encrypted backups	Restricted	Full data-at-rest copy; single point of compromise if key/DPAPI protection fails
Application source code and configuration (config.json, requirements.txt)	Internal	Misconfiguration or exposed secrets could open every asset above

4. Threat Actor Profiles

Actor	Motivation	Capability	Primary vector
Opportunistic outsider	Curiosity, low-effort data theft	Low-Medium (script kiddie tooling, guessing)	Exposed endpoint, weak credentials
Malicious insider (clinician/admin)	Curiosity about a specific client, personal dispute, data resale	Medium (legitimate credentials, domain knowledge)	Excessive record browsing, unauthorized export
Compromised endpoint / malware	Financial (ransomware), espionage	Medium-High (automated, persistent)	Workstation compromise, credential theft, file exfiltration
Careless authorized user	None (unintentional)	N/A	Weak password reuse, unencrypted export sharing, unattended unlocked workstation
Supply-chain / dependency compromise	Broad, opportunistic	Variable	Vulnerable or malicious npm/PyPI package

5. Risk Register

Full risk register, ordered by inherent risk score (descending). Scores follow the 1–25 model in Section 2.1.

ID	Risk	Scenario	Inherent	Band	Key Mitigation(s) — verified in source/tests	Residual
R-02	Credential compromise / account takeover	Weak, reused, or phished clinician password	15	High	bcrypt password hashing (memory-hard KDF), 12-char minimum policy, 5-attempt/15-min account lockout, hashed bearer session tokens with idle+absolute expiry	10
R-04	Broken access control / IDOR	Clinician requests another clinician's records by guessing an ID	15	High	<code>`require_roles()`</code> middleware + <code>`_scoped_clinician_id()`</code> ownership scoping restricts non-admin queries to the authenticated clinician's own records	5
R-11	Malware / ransomware on host workstation	Endpoint compromise encrypts or exfiltrates the local database/backups	15	High	Encrypted backups with offline/off-machine storage recommendation, least-privilege OS accounts recommended in Security Policy; full mitigation depends on institutional endpoint controls outside this application's boundary	15
R-03	Brute-force / credential-stuffing login attempts	Automated guessing against one or many accounts	12	High	New threshold-based intrusion monitor (8 failures/5 min, source- and account-scoped) throttles the source and writes a hash-chained security audit alert; verified by 4 regression tests	4
R-05	Plaintext data at rest (exports/backups)	Exported report or DB backup copied off the workstation unencrypted	12	High	Windows DPAPI protects export files and SQLite backups; SHA-256 digest recorded; restore validated via isolated-directory integrity_check	8
R-06	Plaintext data at rest (live SQLite DB)	Workstation theft or malware reads the live application database file directly	12	High	Partially mitigated: OS-level file permissions, pseudonymous student/patient identifiers (data minimization), local-first (no network exposure) design. NOT mitigated: no column-level encryption of the live DB file. Recommended future enhancement (see Section 8).	12
R-12	Insider misuse (excessive/unauthorized browsing)	A clinician or admin views records outside their duty	12	High	RBAC (admin/clinician/auditor), ownership scoping, and a reviewable hash-chained audit trail create accountability; does not technically prevent an authorized admin from over-broad access — a policy/process control, not a code control	8
R-16	Missing multi-factor authentication for privileged accounts	Single-factor admin credential is phished or reused	12	High	Not yet implemented; spec lists MFA as optional-but-encouraged. Recorded as a release recommendation prior to institutional deployment (Section 8)	12
R-01	SQL injection via crafted identifiers	External/insider attacker submits malicious text through the API	10	Medium	Parameterized <code>`?`</code> bind params used for all caller-supplied values across <code>api_server.py</code> / <code>database_manager.py</code> ; bandit SAST found 0 High findings; 13 Medium f-string-construction findings manually confirmed non-exploitable (query <code>*shape*</code> , not values, is dynamic)	5

ID	Risk	Scenario	Inherent	Band	Key Mitigation(s) — verified in source/tests	Residual
R-07	Consent bypass	Capture starts without recorded informed consent	10	Medium	Consent is enforced server-side (fail-closed) before every capture route responds; <code>`has_active_consent()`</code> checked on each phase transition, not only client-side	5
R-08	Audit log tampering / repudiation	Actor edits or deletes an audit entry to hide an action	10	Medium	Hash-chained audit log (<code>`prev_hash`/`entry_hash`</code>); <code>`verify_audit_chain()`</code> detects any modified row; regression test confirms tamper detection	5
R-09	Session hijacking / token replay	Stolen bearer token reused after logout or expiry	8	Medium	Only a hash of the token is persisted; logout explicitly revokes server-side; idle (15 min) and absolute (8 hr) expiry enforced; regression test confirms revoked tokens fail authentication	4
R-13	Cross-Site Scripting (XSS) in report/UI rendering	Untrusted text rendered into the clinician-facing report or dashboard	8	Medium	React's default output escaping; fixed report templates rather than raw HTML injection from user text	4
R-15	Backup/restore failure or data loss	A backup is corrupt or a restore is never rehearsed	8	Medium	Encrypted backup includes SHA-256 verification and an automated SQLite <code>`integrity_check`</code> restore test in an isolated directory; institutional quarterly restore drills are a proposed operational control (Section 7)	6
R-10	Denial of Service	Repeated requests or oversized payloads exhaust local resources	6	Medium	Loopback-only binding (127.0.0.1), restricted CORS origins, bounded identifier/field lengths on audit endpoints	6
R-14	Vulnerable third-party dependencies (frontend)	Known CVEs in npm packages are exploited	6	Medium	<code>`npm audit`</code> executed 11 Jul 2026: 16 advisories reduced to 8 via non-breaking <code>`npm audit fix`</code> ; 0 remain in shipped runtime dependencies; remaining 8 are confined to build-time devDependencies (Electron/Vite/electron-builder toolchain) not present in the distributed app	3

6. Risk Heat Map (Residual)

Distribution of residual risk after currently-implemented controls:

Band	Count of risks	Risk IDs
Critical	0	—
High	3	R-06, R-11, R-16
Medium	9	R-01, R-02, R-04, R-05, R-07, R-08, R-10, R-12, R-15
Low	4	R-03, R-09, R-13, R-14

No risk in this register scores Critical residual after currently-implemented controls. R-06 (plaintext live database) and R-16 (no MFA) remain the highest residual items and are carried forward as release recommendations in Section 8.

7. Risk Treatment Plan

Risk ID	Treatment Strategy	Planned Action	Owner	Target
R-06	Mitigate	Evaluate column-level or full-database encryption at rest (e.g., SQLCipher) for the live SQLite file, with a deterministic blind-index scheme for fields used in equality lookups	Development team	Pre-institutional deployment
R-16	Mitigate	Implement TOTP-based MFA for administrator accounts; extend to all roles as a stretch goal	Development team	Pre-institutional deployment
R-11	Accept (shared control)	Document minimum endpoint-security baseline (patching, EDR, disk encryption) as an institutional prerequisite in the Security Policy; outside the application's own control boundary	Institution / IT admin	Prior to go-live
R-14	Mitigate (partial — done)	`npm audit fix` applied 11 Jul 2026, resolving 8 of 16 advisories; schedule a major-version upgrade of Electron/Vite/electron-builder to clear the remaining build-time advisories	Development team	Next maintenance cycle
R-12	Mitigate (process control)	Define and enforce a documented access-review cadence (e.g., quarterly export/access log review by an auditor role)	Clinical/ administrative owner	Ongoing, starting at deployment
R-15	Transfer/Mitigate	Adopt the proposed quarterly restore-drill cadence in Section 7 of the thesis Appendix as a standing institutional procedure, evidenced with signed drill records	Institution / IT admin	Quarterly, ongoing

8. Residual Risk Statement

After the controls verified in this assessment, PsyClick Secure's residual risk profile is dominated by Medium-band items, with no Critical-band residual risk identified. Two High-adjacent items — absence of at-rest encryption for the live database (R-06) and absence of multi-factor authentication for privileged accounts (R-16) — are explicitly carried forward as pre-deployment recommendations rather than treated as resolved. This assessment reflects a source-code and static-analysis review; it does not substitute for an independent, authorized dynamic penetration test or a live institutional security audit, both of which remain external deliverables per the companion Security Testing Report.

9. Bibliography

- Grassi, P. A., Garcia, M. E., & Fenton, J. L. (2017). Digital identity guidelines: Authentication and lifecycle management (NIST Special Publication 800-63B). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-63b>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
- International Organization for Standardization. (2022). ISO/IEC 27005:2022 — Information security, cybersecurity and privacy protection — Guidance on managing information security risks. ISO.
- MITRE. (2023). CWE-639: Authorization bypass through user-controlled key. Common Weakness Enumeration.
<https://cwe.mitre.org/data/definitions/639.html>
- National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30 Rev. 1). <https://doi.org/10.6028/NIST.SP.800-30r1>

OWASP Foundation. (2021). OWASP Top 10:2021. <https://owasp.org/Top10/>

Percival, C. (2009). Stronger key derivation via sequential memory-hard functions. Proceedings of BSDCan 2009.

Republic of the Philippines. (2012). Republic Act No. 10173 — Data Privacy Act of 2012. Official Gazette.
<https://www.officialgazette.gov.ph/2012/08/15/republic-act-no-10173/>

Zetetic LLC. (2023). SQLCipher: Full-database encryption for SQLite. <https://www.zetetic.net/sqlcipher/>

10. Approval

Role	Name	Signature	Date
Prepared by	PsyClick thesis team		
Reviewed by (Clinical Lead)			
Reviewed by (Adviser)	Mr. Justine Jude C. Pura		